Sicurezza dei Sistemi Informativi

Appello d'Esame del 14 Febbraio 2025

Anno Accademico 2024-2025

Politecnico di Torino — Docente: Prof. Cataldo Basile

2025-02-14

1 Testo Ufficiale dell'Esame

Parte 1: Quiz Ufficiale su Piattaforma d'Esame

Valutare ciascuna delle affermazioni selezionando quelle corrette per ciascun gruppo di quesiti:

1.1 Sicurezza di Rete e Monitoraggio:

a. Un WAF, posto in un gateway in modalità stealth, è in grado di filtrare il traffico di applicazioni web anche se queste sono cifrate mediante TLS.

b. In un'architettura di tipo *screened host gateway* si può mascherare la rete interna solo se il router di bordo implementa anche funzioni di NAT.

c. Data breach è un incidente per cui è stato confermato che dei dati sono stati effettivamente rivelati (non solo esposti) a persone non autorizzate.

d. Definire quale è il traffico autorizzato è uno dei problemi principali per la corretta configurazione di un firewall.

e. Gli IDS avanzati basati su AI permettono di identificare e reagire alle minacce in maniera efficace.

f. Un application-level filter permette di definire regole di autorizzazione più granulari rispetto ad un packet filter, perché è in grado di comprendere la semantica e la sintassi del protocollo che si intende filtrare.

g. Un network-based IDS monitora il traffico di una sottorete ma non è pensato per identificare attacchi provenienti da Internet.

h. In un SOC non dovrebbero esserci esperti di analisi forense, perché lo scopo principale è monitorare, identificare ed evitare gli attacchi.

i. Un SIEM serve a collezionare e analizzare dati ai fini di monitoring oltre a permettere di generare report utili anche per verifiche di compliance.

1.2 Protocolli di Autenticazione e Controllo Accessi di Rete:

a. PPP serve ad incapsulare pacchetti di livello 3 per trasferimenti punto-punto.

b. Per come è progettato, EAP richiede frequenti cambiamenti allo standard, in pratica ogni volta che è necessario aggiungere un nuovo tipo di autenticazione.

c. Le funzioni di sicurezza intrinseche di RADIUS sono insufficienti.

d. Il protocollo RADIUS permette di incapsulare messaggi EAP.

e. I server RADIUS possono fare da proxy, ma solo verso altri server RADIUS.

f. EAP è un middleware che permette di usare diversi tipi di autenticazione con diversi tipi di protocolli di comunicazione di livello 2.

g. Eduroam richiede una condivisione minima di segreti utenti tra istituzioni federate.

h. PAP è ancora considerato un metodo di autenticazione valido.

i. Se si usa 802.1X, gli AP non devono necessariamente autenticare gli utenti direttamente.

1.3 Identità Digitale e Meccanismi di Autenticazione:

a. Nel Digital Authentication Model del NIST, il Credential Service Provider ha il compito di emettere o registrare le credenziali degli utenti e gli altri attributi ad essi associati.

b. Un dictionary attack ha, a parità di tempo a disposizione, una maggiore probabilità di identificare le password degli utenti rispetto ad un approccio a forza bruta, considerando che molti sceglieranno password deboli.

c. Un password wallet è un esempio semplice ed efficace di Single Sign-On che rispetta tutti i requisiti di un SSO multi-dominio e multi-applicazione.

d. In Kerberos, gli Application Server ricevono dal Ticket Granting Server le chiavi degli utenti.

e. Il token FIDO2 svolge anche il ruolo di fattore di autenticazione di tipo "possesso".

f. L'autenticazione mediante dispositivo personale, nella versione che sfrutta l'inerenza, viene ritenuta molto sicura.

g. Un approccio di tipo Zero-Knowledge Proof include anche il caso in cui un Verifier possa fare centinaia di domande ad un Prover prima di garantire l'autenticazione.

h. I CRA asimmetrici sono resistenti allo sniffing.

1.4 Infrastruttura a Chiave Pubblica (PKI) e Firme Digitali:

a. L'OCSP mi permette di identificare le firme che non sono valide perché posso capire se il certificato era valido al momento della firma.

b. La fiducia nei certificati digitali degli utenti, in realtà, dipende dalla fiducia nelle autorità di certificazione che li hanno emessi (se la crittografia è forte ed usata correttamente).

c. L'algoritmo di Grover renderà facilmente attaccabili le firme digitali calcolate con gli algoritmi della crittografia classica (es. RSA, DSA).

d. Un documento contenente una macro può essere firmato, ma viene garantita l'integrità e autenticazione del codice della macro stessa, non il risultato di quello che verrà calcolato o cambiato sul documento.

e. Un certificato X.509 di tipo Diffie-Hellman riporterà tre parametri: il numero primo p, il generatore g e $g^x \bmod p$, dove x è il parametro privato del possessore del certificato.

f. Un documento firmato include un Time-Stamp ottenuto da una TSA fidata e riporta come data e ora il 14/02/2025 alle 14:00. Posso quindi escludere che il documento esistesse già il 13/02/2025.

g. Dato un documento che deve essere firmato da n firmatari, se si scegliesse di usare firme sequenziali la verifica richiederebbe più tempo rispetto al caso in cui si scegliesse l'uso di firme parallele.

1.5 Sicurezza Software, Standard e Crittografia Pratica:

a. Una vulnerabilità del tipo buffer overflow potrebbe permettere agli attaccanti di prendere il controllo di un server remoto.

b. La certificazione di sicurezza aumenta la nostra fiducia nel prodotto certificato perché sappiamo che qualcuno ha verificato che determinate proprietà di sicurezza siano soddisfatte.

c. Il processo di valutazione definito nello standard ITSEC si concentra su efficacia delle soluzioni e correttezza dell'implementazione.

d. Bisogna cambiare spesso le chiavi crittografiche simmetriche usate per garantire la confidenzialità del traffico di rete, perché gli attaccanti potrebbero ricavare dal traffico cifrato informazioni utili a decifrarlo.

e. Senza l'opzione `-no-pad` (OpenSSL), cifrare 16 byte con AES128-ECB è preferibile rispetto ad usare AES128-CBC, considerando sicurezza e spreco di dati.

f. La crittografia a curve ellittiche costruisce algoritmi di crittografia asimmetrica a partire da problemi difficili su campi matematici ottenuti da equazioni del tipo $y^2 = x^3 + ax + b$.

g. Gli algoritmi di Hash vengono usati per generare le chiavi che garantiscono confidenzialità e integrità+autenticazione nel TLS.

h. Se l'ultimo blocco di dati cifrato con DES termina con `0x1324354603030303` verrà accettato correttamente sia con che senza l'opzione `-no-pad` (OpenSSL).

Parte 2: Domande a Risposta Aperta (Compito Scritto)

Domanda 1: NIST RMF e Enterprise Patch Management

a. Spiegare cosa è il Risk Management Framework (RMF) del NIST (SP 800-37) e quali sono gli obiettivi di tale framework. Elencare e descrivere le 7 fasi e alcune delle operazioni che potrebbero essere svolte in ognuna di esse.

b. Spiegare cosa è l'Enterprise Patch Management (NIST SP 800-40), quali sono i suoi obiettivi operativi e citare almeno due aspetti e sfide rilevanti (es. prioritizzazione basata su CVSS/EPSS, test preventivi di regressione in ambiente di staging).

Domanda 2: Progettazione Architettura di Rete Sicura Progettare un'infrastruttura di rete sicura per un'azienda dotata di sede centrale, DMZ con servizi esposti e lavoratori remoti. Discutere le tecnologie impiegate (Firewall stateful, VPN IPsec/TLS, RADIUS/802.1X, MFA) e dettagliare la matrice di autorizzazione.

2 Soluzione Dettagliata e Guida Risolutiva

Soluzione Parte 1: Analisi Dettagliata del Quiz Ufficiale

1.1 Sicurezza di Rete e Monitoraggio (Analisi Puntuale delle Opzioni):

- **a. FALSA**: Un Web Application Firewall (WAF) collocato in modalità *stealth* trasparente (bridge L2) non può ispezionare né filtrare il traffico applicativo HTTP cifrato con TLS se non possiede i certificati digitali e la relativa chiave privata per terminare o intercettare la sessione crittografica.
- **b. VERA**: Nell'architettura *screened host gateway*, il packet filtering router convoglia il traffico pubblico sul bastion host esposto; per mascherare e proteggere la sottorete interna privata (RFC 1918), il router di bordo deve obbligatoriamente implementare funzioni di Network Address Translation (NAT/NAPT).
- **c. FALSA**: Ai sensi dell'Art. 4.12 del GDPR, per "violazione dei dati personali" (*data breach*) si intende qualsiasi violazione di sicurezza che comporti accidentalmente o in modo illecito la distruzione, la perdita, la modifica, la divulgazione non autorizzata o l'accesso ai dati; l'esposizione indebita di dati non protetti configura già un breach conclamato anche in assenza di prove di effettiva esfiltrazione attiva.
- **d. VERA**: Definire con precisione cosa costituisca traffico lecito rispetto alle esigenze aziendali (*Authorized Traffic Baseline*) è una delle sfide più critiche ed esposte a fallacie nella configurazione delle regole di un firewall.
- **e. FALSA**: Gli IDS basati su modelli di machine learning e intelligenza artificiale soffrono storicamente di elevati tassi di falsi positivi dovuti al mutamento dei pattern di traffico (*concept drift*); una risposta automatica non supervisionata rischia di bloccare servizi operativi legittimi generando Denial of Service auto-indotti.
- **f. VERA**: Un filtro applicativo (L7) esegue il riassemblaggio dello stack e l'analisi semantica e sintattica del protocollo (es. comandi HTTP, query SQL, intestazioni MIME), consentendo politiche di autorizzazione contestuali inaccessibili a un packet filter L3/L4.
- **g. FALSA**: I Network-based IDS (NIDS) sono concepiti e posizionati strategicamente proprio ai confini perimetrali (a monte o a valle del firewall) per rilevare intrusioni, scansioni ed exploit provenienti da Internet verso le risorse aziendali.
- **h. FALSA**: Il Security Operations Center (SOC) moderno integra necessariamente competenze di Digital Forensics & Incident Response (DFIR) per raccogliere prove conformi a valore legale, determinare la causa radice (*root cause*) dell'incidente e valutare la persistenza delle minacce.
- **i. VERA**: La piattaforma SIEM (*Security Information and Event Management*) centralizza, normalizza e correla i log di rete, fornendo dashboard di monitoraggio operativo e audit trail conformi a standard di compliance (GDPR, ISO/IEC 27001, PCI-DSS).

1.2 Protocolli di Autenticazione e Controllo Accessi di Rete:

- **a. VERA**: Il Point-to-Point Protocol (PPP, RFC 1661) è formalmente progettato per incapsulare datagrammi multi-protocollo di livello 3 su collegamenti punto-a-punto diretti.

- **b. FALSA**: L'Extensible Authentication Protocol (EAP, RFC 3748) è un framework estensibile per design; supporta l'integrazione di nuovi algoritmi di autenticazione semplicemente assegnando un nuovo *Type Code* numerico, senza richiedere modifiche allo standard di base.

- **c. VERA**: Le specifiche originarie di RADIUS (RFC 2865) sono crittograficamente carenti: proteggono solo il campo password tramite un meccanismo debole basato su MD5 e segreto condiviso, trasmettono tutti gli altri attributi utente in chiaro e non garantiscono integrità end-to-end su tutti i pacchetti (motivo per cui si adotta RadSec con TLS, RFC 6614).

- **d. VERA**: Lo standard RFC 3579 specifica formalmente come i messaggi EAP siano incapsulati all'interno degli attributi `EAP-Message` e protetti dall'attributo `Message-Authenticator` di RADIUS.

- **e. VERA**: I server RADIUS supportano il routing e forwarding gerarchico dei pacchetti di autenticazione tramite il meccanismo di *RADIUS Proxying*, operando nativamente solo verso altri server che condividono il medesimo protocollo.

- **f. VERA**: EAP opera come un livello *middleware* universale di astrazione, disaccoppiando i meccanismi di autenticazione (EAP-TLS, PEAP, EAP-TTLS) dai protocolli di trasporto di livello 2 sottostanti (IEEE 802.1X, PPP).

- **g. VERA**: Nell'infrastruttura mondiale Eduroam, le istituzioni federate instradano le richieste tramite proxy RADIUS basati sul realm dell'utente; l'ateneo ospitante non conosce né condivide i segreti crittografici dell'utente, che vengono verificati unicamente dall'ateneo di appartenenza.

- **h. FALSA**: Il Password Authentication Protocol (PAP) trasmette le credenziali in chiaro sul canale di comunicazione senza alcuna protezione crittografica, risultando completamente obsoleto e vulnerabile a qualsiasi intercettazione.

- **i. VERA**: Nel modello IEEE 802.1X, l'Access Point (AP) assume il ruolo di mero *Authenticator* passante: inoltra i frame EAPoL al server di autenticazione backend (RADIUS), senza dover convalidare né gestire direttamente le credenziali.

1.3 Identità Digitale e Meccanismi di Autenticazione:

- **a. VERA**: Nelle linee guida NIST SP 800-63-3, il Credential Service Provider (CSP) è l'entità fidata responsabile della fase di enrollment, verifica dell'identità ed emissione/registrazione delle credenziali degli abbonati.

- **b. VERA**: Gli attacchi a dizionario (*Dictionary Attacks*) sfruttano la ridotta entropia delle scelte umane; testando termini ad alta frequenza hanno un'efficienza temporale e una probabilità di successo enormemente superiori rispetto alla forza bruta esaustiva dello spazio delle chiavi.

- **c. FALSA**: Un password wallet è un gestore locale di credenziali memorizzate/cifrate (es. KeePass), non un protocollo di autenticazione Single Sign-On (SSO) federato multi-dominio (come SAML 2.0, OpenID Connect o Kerberos).

- **d. FALSA**: In Kerberos (RFC 4120), l'Application Server non riceve mai le chiavi segrete degli utenti; riceve dal client un Service Ticket cifrato con la propria chiave di servizio K_S, all'interno del quale è inclusa una chiave di sessione effimera $K_{C,S}$.

- **e. VERA**: Il token hardware FIDO2 (es. YubiKey) funge primariamente da fattore di possesso fisico (*Something you have*), contenente la chiave privata asimmetrica custodita in un chip Secure Element non clonabile.
- **f. VERA**: L'autenticazione biometrica su dispositivo personale (*Something you are*) è considerata altamente sicura poiché il template biometrico viene memorizzato e confrontato esclusivamente nell'enclave hardware sicura locale (Secure Enclave / TPM), senza mai viaggiare sulla rete.
- **g. VERA**: Nei protocolli Zero-Knowledge Proof (ZKP) interattivi (come Fiat-Shamir o Guillou-Quisquater), il Verifier sottopone il Prover a molteplici iterazioni di challenge casuali; la probabilità di superare la prova barando è $(1/2)^k$, richiedendo centinaia di iterazioni per raggiungere una confidenza computazionale elevata.
- **h. VERA**: Nei protocolli Challenge-Response Authentication (CRA) asimmetrici, il richiedente firma il challenge con la propria chiave privata; l'intercettazione passiva di challenge e firma non consente all'attaccante di estrarre la chiave privata.

1.4 Infrastruttura a Chiave Pubblica (PKI) e Firme Digitali:

- **a. FALSA**: Il protocollo OCSP (RFC 6960) certifica lo stato di revoca **attuale** del certificato al momento della richiesta; non fornisce la prova retroattiva che il certificato fosse valido al momento storico in cui la firma è stata apposta (per cui è indispensabile la marca temporale TSA conforme a RFC 3161 e formati Long Term Validation come PAdES/CAdES-LTV).
- **b. VERA**: La validità crittografica di un certificato X.509 poggia interamente sulla fiducia transitiva nella catena di certificazione che risale a una Root CA trusted installata nel Trust Store.
- **c. FALSA**: L'algoritmo quantistico di Grover accelera la ricerca non strutturata dimezzando la sicurezza effettiva dei cifrari simmetrici e delle funzioni hash (da N a $\sqrt{N}$); è l'algoritmo di **Shor** che abbatte in tempo polinomiale i problemi di fattorizzazione (RSA) e logaritmo discreto (DSA, ECDSA).
- **d. VERA**: La firma digitale su un documento garantisce l'integrità e l'autenticità del codice statico della macro così com'è stato firmato; non può garantire l'esito né le modifiche dinamiche che il codice della macro produrrà a runtime durante l'esecuzione sul computer della vittima.
- **e. VERA**: Un certificato per scambio Diffie-Hellman statico riporta nel campo SubjectPublicKeyInfo i parametri pubblici di gruppo (p, g) e il valore pubblico effettivo $Y = g^x \bmod p$.
- **f. FALSA**: La marca temporale (Time-Stamp) attesta che il documento esisteva **al più tardi** alla data e ora certificate dalla TSA (14/02/2025 14:00); ciò non esclude affatto che il file fosse già stato redatto o esistente in date anteriori (es. 13/02/2025).
- **g. VERA**: Nelle firme sequenziali ogni firma incapsula la precedente creando una struttura a strati (*onion*) che impone una verifica strettamente sequenziale; nelle firme parallele ogni firma è indipendente e riferita al medesimo hash di base, permettendo la verifica parallela e concorrente su più core CPU.

1.5 Sicurezza Software, Standard e Crittografia Pratica:

- **a. VERA**: Sovrascrivendo l'indirizzo di ritorno sullo stack (*Saved RIP*) o puntatori a funzione nell'heap, un attacco di buffer overflow può deviare il flusso di esecuzione verso shellcode o catene ROP conseguendo la Remote Code Execution (RCE) con privilegi di root/amministratore.
- **b. VERA**: La certificazione di sicurezza di terza parte indipendente (Common Criteria ISO/IEC 15408) fornisce una garanzia formale (*Assurance*) che il prodotto rispetti rigorosamente i requisiti funzionali e di correttezza dichiarati nel Security Target.
- **c. VERA**: Nello standard ITSEC la valutazione è strutturata sui due criteri cardine inscindibili di **Efficacia** (adeguatezza delle funzionalità di sicurezza) e **Correttezza** (qualità ingegneristica e assenza di difetti di sviluppo da E1 a E6).
- **d. VERA**: Il ricambio periodico delle chiavi simmetriche (*re-keying*) limita il volume di ciphertext generato sotto la stessa chiave, prevenendo attacchi basati su collisioni statistiche (es. Sweet32 dopo 2^{32} blocchi) e saturazione del keystream.
- **e. FALSA**: La modalità ECB è intrinsecamente insicura e proibita poiché cifra blocchi di testo identici in blocchi cifrati identici senza vettore di inizializzazione; la modalità CBC con IV casuale e impredicibile è sempre superiore e sicura (IND-CPA), a prescindere dal byte di padding.
- **f. VERA**: La crittografia ellittica standardizzata opera su gruppi ciclici di punti che soddisfano l'equazione di Weierstrass $y^2 = x^3 + ax + b$ definita su campi finiti primi $\mathbb{F}_p$ o binari $\mathbb{F}_{2^m}$.
- **g. VERA**: In TLS, le funzioni di hash pilotano la Pseudo-Random Function (PRF basata su HMAC-SHA256 in TLS 1.2) e il framework HKDF (in TLS 1.3) per espandere il Master Secret nelle chiavi simmetriche di cifratura e nei vettori di inizializzazione.
- **h. VERA**: Su un blocco DES da 8 byte, la sequenza terminale `03030303` rappresenta un padding PKCS#7 formalmente valido di 4 byte (ripetizione del valore numerico 4 non presente, mentre per 4 byte di padding il byte corretto è `0x04`; se la sequenza termina con quattro byte uguali a `0x03` ciò rappresenta 3 byte di padding `030303` validi). Con `-no-pad` il testo decifrato viene restituito integralmente; con padding abilitato il parser rimuove i byte di conformità senza generare errori di decifratura.

Soluzione Parte 2: Risposta Aperta

1.a NIST Risk Management Framework (RMF SP 800-37 Rev. 2): Il framework RMF fornisce una metodologia olistica a 7 fasi per integrare la sicurezza e la privacy nel ciclo di vita dei sistemi informativi:

1. **Prepare**: Allineamento della governance aziendale, definizione della tolleranza al rischio (*Risk Appetite*) e identificazione degli stakeholder.
2. **Categorize**: Classificazione dei dati e del sistema informativo in base all'impatto potenziale (Low, Moderate, High per Confidenzialità, Integrità, Disponibilità) secondo FIPS 199 e NIST SP 800-60.

3. **Select**: Scelta della baseline di controlli di sicurezza da NIST SP 800-53 Rev. 5 e applicazione delle procedure di *tailoring* in base al contesto operativo.

4. **Implement**: Integrazione tecnica e organizzativa dei controlli all'interno dell'architettura aziendale.

5. **Assess**: Valutazione indipendente dell'efficacia dei controlli tramite test di sicurezza, vulnerability assessment e audit per accertare che operino come previsto.

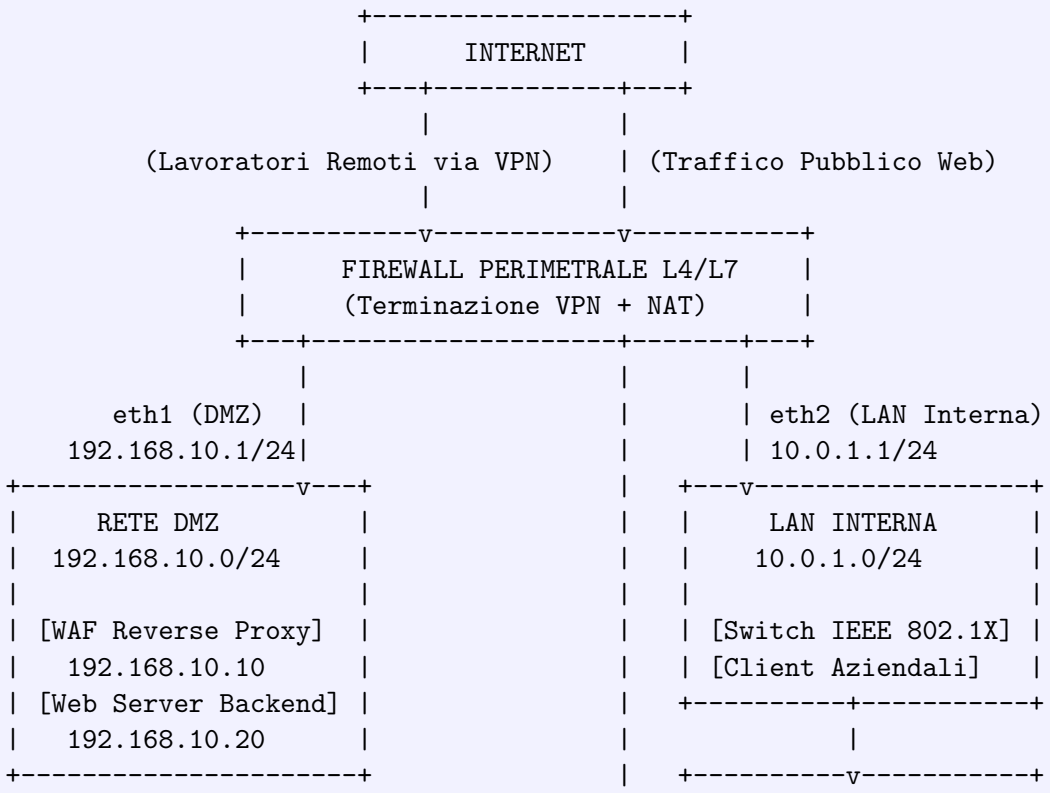
6. **Authorize**: Decisione formale del responsabile autorizzante (*Authorizing Official*) sul rilascio dell'Authority to Operate (ATO) in base al rischio residuo.

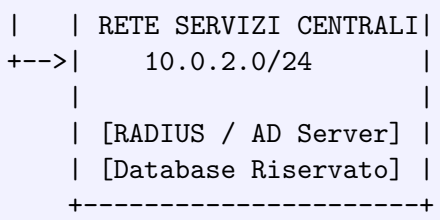
7. **Monitor**: Monitoraggio continuo della postura di sicurezza, scansione di nuove vulnerabilità e rivalutazione periodica dei rischi.

1.b Enterprise Patch Management (NIST SP 800-40 Rev. 4): Disciplina il processo di acquisizione, collaudo e installazione tempestiva degli aggiornamenti software per ridurre la superficie di attacco esposta agli exploit.

- **Prioritizzazione del Rischio basata su CVSS ed EPSS**: Di fronte a decine di migliaia di nuove CVE annuali, il patching indiscriminato è impraticabile. Si integrano le metriche di severità intrinseca (CVSS) con metriche di probabilità di sfruttamento reale sul campo (**EPSS - Exploit Prediction Scoring System**) e con i cataloghi di minaccia attiva (CISA KEV).
- **Testing Preventivo in Ambiente di Staging**: Per evitare blocchi dei servizi di produzione (*service outage*) causati da regressioni o conflitti software, le patch devono essere collaudate in un ambiente di pre-produzione speculare prima del rilascio definitivo.

2. Progettazione Architettura di Rete Sicura:





Tecnologie e Regole di Autorizzazione Applicate:

- **Accesso Remoto Sicuro**: Connessione VPN IPsec IKEv2 o TLS (OpenVPN/WireGuard) con autenticazione a più fattori obbligatoria (MFA con token hardware FIDO2) e verifica di conformità del dispositivo client (*Posture Checking*).
- **Controllo Accessi LAN**: Porte di accesso Ethernet e Wi-Fi governate da switch con IEEE 802.1X: il traffico dell'utente viene bloccato finché il server centrale RADIUS/Active Directory non autentica l'identità tramite certificato client (EAP-TLS).
- **Ispezione Perimetrale DMZ**: Il traffico Web esterno è indirizzato unicamente al WAF Reverse Proxy (`192.168.10.10`); nessun host Internet o DMZ può avviare connessioni arbitrarie verso la LAN o i server interni.

Alternative Implementation Note: Concorrenza Rust in Sistemi di Logging e Patching

Nei sistemi di auditing e inventory aziendale conformi alle linee guida NIST:

- Si utilizza `tokio::sync::broadcast` per distribuire le notifiche di emergenza sulle nuove CVE a tutti i microservizi attivi.
- `std::sync::RwLock`: Per gestire la cache locale delle policy di compliance, garantendo throughput massimale in lettura da parte dei thread di monitoraggio.